

System architecture and discovery

Actual stack inventory

Layer	Implemented technology	Evidence
Web	React 18, TypeScript, Vite, React Router, TanStack Query, Radix/shadcn, Tailwind, i18next	root package.json, src/App.tsx
Mobile	Expo 51, React Native 0.74, Firebase, React Navigation; native iOS and Android projects	mobile/package.json, mobile/app.config.ts
API	Node/Express/TypeScript, Zod, WebSocket	server/src/index.ts, route registry
Identity	Firebase ID tokens and custom role claim	Firebase auth provider, require-auth.ts
Data	PostgreSQL 15 via RDS Proxy/pg; Redis; seven DynamoDB event/log tables	CDK, migrations, provider registry
Files	Private S3 buckets, presigned/proxy upload, CloudFront media CDN	storage routes/controller, CDK
Async	SQS/DLQ notification worker; in-process timers for rollups/supply jobs	CDK, server/src/index.ts
External	Razorpay, Vertex Gemini, Google Maps/TTS, Bhashini, Firebase, SES/SNS/SMTP/FCM, Mixpanel adapters	config schemas/providers
Infrastructure	AWS CDK: VPC/NAT, public ALB, ECS Fargate, RDS, proxy, ElastiCache, DynamoDB, S3, CloudFront, WAF, alarms	infrastructure/lib/*.ts

Repository map

Path	Role	Inspection status
src/	Production web SPA	Inspected entrypoints, routes, auth, marketplace, payments, legal/support, analytics
server/src/	API/domain implementation	Inspected routes, auth, storage, bookings/payments, admin, safety, KYC, jobs, logging
server/migrations/	Portable PostgreSQL schema/migrations	Table/index/constraint inventory inspected; runtime migration blocked by Docker daemon
mobile/	Expo/RN app and native projects	Entry, navigator, auth/onboarding, privacy, booking, config/manifests inspected
infrastructure/	CDK stacks	Full stack synthesized and security/cost resources inspected
services/image-moderation/	Python NSFW/category service	Source/requirements/test presence inspected; model runtime not exercised
loadtest/	k6 smoke/sustained scripts	Inspected; not executed against staging
redesign-client/	Separate prototype/client	Inspected at manifest level; not treated as production entrypoint
supabase/	Legacy functions/migrations	Sampled; appears residual alongside Express/AWS path
node_modules, generated dist, cdk.out, binaries/media	Generated/dependency artifacts	Excluded from manual source review; package audits and output sizes inspected

Tracked-file inventory reported 1,045 files in the engineering review. No AGENTS.md was present. README/architecture documents were treated as claims and cross-checked against source.

Entry and deployment map

```
flowchart LR
    U["Web / Expo users"] --> F["Firebase identity"]
    U --> CF["CloudFront + WAF"]
```

```

CF --> S3["S3 web origin"]
CF --> ALB["Public ALB (HTTP origin)"]
U -. "direct-origin bypass risk" .-> ALB
ALB --> ECS["ECS Fargate Express API"]
ECS --> RP["RDS Proxy"] --> PG["PostgreSQL 15"]
ECS --> R["ElastiCache Redis"]
ECS --> D["DynamoDB event tables"]
ECS --> Q["SQS / DLQ"]
ECS --> B["Private S3 buckets"]
ECS --> X["Razorpay / Google / Firebase / Bhashini / SES-SNS-FCM"]

```

The web deployment uploads dist/ to the frontend bucket and invalidates CloudFront. Mobile distribution is intended through EAS, but eas.projectId, app identity/artwork and association files are incomplete. There are no tracked CI workflows.

Trust boundaries and auth map

```

flowchart TB
    subgraph Untrusted
        W["Browser"]
        M["Mobile app"]
    end
    subgraph Identity
        FB["Firebase Auth"]
    end
    subgraph Edge
        C["CloudFront/WAF"]
        L["Public ALB"]
    end
    subgraph Private_AWS["Private AWS networking"]
        A["Express API"]
        P["Postgres"]
        R["Redis"]
        D["DynamoDB"]
        S["S3"]
    end
    W --> FB
    M --> FB
    W --> C
    M --> C
    C --> L --> A
    A --> P
    A --> R
    A --> D
    A --> S

```

HTTP APIs use Authorization: Bearer . requireAuth verifies tokens; admin routes then require the admin custom claim. Storage upload enforces user-key ownership, but download/delete/list do not. Realtime generic channels accept arbitrary subscriptions; WebSocket tokens are placed in query strings. Rate limiters run before route authentication, so their intended user key is unavailable and IP is used.

Core entity map

```

erDiagram
    USER_PROFILES ||--o{ PROVIDER_PROFILES : owns
    USER_PROFILES ||--o{ LISTINGS : owns
    PROVIDER_PROFILES ||--o{ LISTINGS : supplies
    LISTINGS ||--o{ LISTING_ROOM_TYPES : has
    USER_PROFILES ||--o{ BOOKINGS : books
    LISTINGS ||--o{ BOOKINGS : fulfills
    BOOKINGS ||--o{ PAYMENTS : pays
    BOOKINGS ||--o{ REVIEWS : reviews
    BOOKINGS ||--o{ MESSAGES : contextualizes
    USER_PROFILES ||--o{ CONSENTS : grants
    USER_PROFILES ||--o{ VERIFICATION_DOCUMENTS : submits
    COUPONS ||--o{ COUPON_REDEMPTIONS : consumed
    PROVIDER_PROFILES ||--o{ PAYOUTS : receives

```

Additional stores include conversations/assistant memory, safety alerts/checks, notifications/FCM tokens, wishlists, insurance/guarantees, fraud/admin actions, analytics rollups/device links, translation cache and image-moderation labels.

Cost-driver map

Driver	Trigger	Fixed/variable	Evidence
Production RDS Multi-AZ + read replica + proxy	always on	Fixed	CDK lines 172-239
Redis r6g.large prod	always on	Fixed	CDK lines 249-256
NAT, ALB, WAF, Fargate	always on / traffic	Mostly fixed	CDK
Gemini	assistant/onboarding/voice turns	Variable, denial-of-wallet	provider code and cost PDF
Google Places	autocomplete/details	Variable after caps	geocode service/PDF
Razorpay	booking GMV	Variable; often pass-through	payments/PDF
OTP/SMS/email	registration and notifications	Variable	auth/notifications/PDF
DynamoDB/logging	event per action/request	Variable	provider tables/PDF

Undocumented or unproven assumptions

- * The PDF references scratchpad/sim/ raw artifacts, but that directory is absent; exact 1,000-user results are not independently reproducible from this checkout.
- * The RDS read replica is provisioned but no read-routing implementation was found.
- * A backup S3 bucket exists, but no database-export job or restore drill evidence exists.
- * Alarm topic subscription is a manual post-deploy action; an actual recipient is missing evidence.
- * Staging/production provider credentials, vendor contracts, app-store records and deployed AWS settings were not available.

Findings

ID	Domain	Title	Severity	Confidence	Evidence	User/business impact	Recommended correction	Effort	Owner	Release blocker	Status
ARC-001	Architecture	Public ALB bypasses edge controls	High	High confidence	CDK public ALB + HTTP origin	WAF/TLS bypass	Private/restricted authenticated origin	Medium	DevOps	yes	Open
ARC-002	Architecture/Cost	Paid read replica has no read routing	Medium	Probable	CDK + single DB provider	Waste; no scale benefit	Remove until needed or implement routing	Low/High	CTO/DBA	no	Open
ARC-003	Reliability	Per-task scheduled jobs duplicate work	Medium	Confirmed	server/src/index.ts intervals	Multiplicative load/cost	EventBridge singleton jobs	Medium	Backend/SRE	before 1K	Open
ARC-004	Release	Multiple legacy/proto type paths obscure source of truth	Low	Confirmed	supabase/, redesign-client/	Maintenance/deploy mistakes	Archive or document ownership	Medium	CTO	no	Open